Replace and modernize legacy VPN architectures with a cloud-native Zscaler Zero Trust solution to reduce attack surface and lateral movement.

TEAM DETAILS

S.NO	NAME	COLLEGE	CONTACT
1	M.RASHIDA PARVEEN	St.joseph's college for women,Tiruppur	rashidaparveenazlan14@gmail.com
2	S.JENIFER	St.joseph's college for women,Tiruppur	Jeniferstephenraj25@gmail.com
3	R.GOPIKA	St.joseph's college for women,Tiruppur	rgopikaramesh2006@gmail.com
4	P.SARJANA DEVI	St.joseph's college for women,Tiruppur	sarjanadevidevi@gmail.com

PROJECT DETAILS

Title: Replace and modernize legacy VPN architectures with a cloud-native Zscaler Zero Trust solution to reduce attack surface and lateral movement.

In response to the evolving threat landscape and the dissolution of the traditional network perimeter, this project initiates a fundamental shift in our security architecture. We will be decommissioning our legacy VPN infrastructure, which relies on an outdated castle-and-moat model that grants excessive network access and is vulnerable to lateral threat movement. To replace it, we are adopting a cloud-native, Zero Trust approach powered by Zscaler. This new architecture is built on the principle of "never trust, always verify," ensuring that users are connected to applications, not to the network. By making applications invisible to the internet and establishing direct, secure user-to-app connections, we will drastically reduce our attack surface. This modern solution eliminates the risk of lateral movement, as threats can no longer traverse a flat network. Furthermore, it provides a superior, high-performance experience for our hybrid workforce, decoupling security from data center backhauling.

In today's digital era, organizations are rapidly shifting from traditional data centers to cloud-based infrastructures. The rise of Software-as-a-Service (SaaS), remote workforce models, and hybrid cloud environments has exposed the limitations of legacy VPN-based security architectures. VPNs were originally designed to connect remote users to internal corporate networks, but they provide broad network-level access, increasing the risk of unauthorized access and internal attacks.

Modern cybersecurity strategies now emphasize Zero Trust architecture, which assumes that no user or device should be trusted by default. Instead of granting full network access, Zero Trust provides secure, identity-based access to specific applications. Zscaler offers a cloud-native Zero Trust platform that replaces traditional VPN solutions with secure, scalable, and direct-to-cloud connectivity.

By adopting Zscaler's Zero Trust approach, organizations can reduce their attack surface, prevent lateral movement within the network, and simplify security management. This transition from legacy VPN to a cloud-native architecture supports business agility, enhances performance, and ensures strong protection against modern cyber threats

Abstract:

Traditional VPN-based security architectures were designed for on-premises environments where users and applications were located inside a corporate network perimeter. However, with the rapid adoption of cloud computing, remote work, and mobile access, legacy VPN solutions have become complex, costly, and vulnerable to cyber threats. VPNs extend the network to users, which increases the attack surface and enables lateral movement once an attacker gains access.This project focuses on replacing traditional VPN architectures with a cloud-native Zero Trust solution using Zscaler. The Zero Trust model follows the principle of "never trust, always verify," ensuring that users are granted access only to specific applications rather than the entire network. By implementing Zscaler's cloud-based security platform, organizations can reduce security risks, eliminate unnecessary network exposure, and improve overall performance and scalability.The proposed solution enhances security by minimizing lateral movement, enforcing identity-based access control, and delivering secure connectivity directly through the cloud. This modernized architecture supports digital transformation while ensuring stronger protection against evolving cyber threats.

Use Case Scenarios:

Scenario 1: Secure Remote Workforce Access

In many organizations, employees work remotely and require secure access to company applications. Traditional VPNs allow users to connect to the entire network, which increases security risks if a device is compromised. With a Zero Trust approach using Zscaler, users are authenticated based on identity, device posture, and policy before accessing specific applications. This ensures employees can safely connect from anywhere without exposing the internal network.

Output:

- Secure application access for remote employees
- No full network exposure
- Reduced risk of cyber attacks
- Improved user experience and connectivity

Scenario 2: Secure Access for Third-Party Vendors

Organizations often provide external vendors or partners with access to internal applications. Using traditional VPNs, vendors may receive broader network access than necessary. With Zero Trust implemented through Zscaler, vendors are granted limited access only to the required applications. This minimizes security risks and prevents unauthorized access to sensitive resources.

Output:

- Restricted application-level access for vendors
- Better control over external user permissions
- Reduced risk of data leakage
- Secure collaboration with partners

Scenario 3: Protection Against Lateral Movement

In traditional VPN environments, once an attacker gains access to the network, they may move laterally to other systems. Zero Trust architecture prevents this by isolating applications and verifying each connection request. With the help of Zscaler, users can only access the applications they are authorized to use, stopping attackers from spreading across the network.The system continuously monitors user activities and network traffic. Any suspicious behavior can be detected and blocked immediately. This significantly improves the organization's ability to defend against internal and external threats.

Output:

- Limited access to authorized applications only
- Prevention of internal threat spread
- Reduced attack surface
- Improved overall network security

Scenario 4: Secure Access to Cloud Applications

Many businesses use cloud applications such as SaaS platforms for daily operations. Traditional VPNs route traffic through corporate data centers, causing latency and performance issues. A cloud-native Zero Trust platform like Zscaler provides direct and secure access to cloud applications without routing traffic through the internal network.This architecture improves network efficiency and reduces delays in accessing applications. Security policies are applied directly in the cloud environment. As a result, users can access applications quickly while maintaining strong security controls.

Output:

- Faster access to cloud applications
- Reduced network latency
- Improved user productivity
- Secure direct-to-cloud connectivity

Scenario 5: Simplified Network Security Management

Managing multiple VPN devices, firewalls, and security appliances can be complex and expensive. A cloud-native Zero Trust platform like Zscaler centralizes security policies and access control in the cloud. This simplifies administration and allows IT teams to manage security policies more efficiently.Administrators can monitor user activities and network access through a centralized dashboard. Policy updates can be implemented quickly across the entire system. This reduces operational overhead and ensures consistent security enforcement.

Output:

- Centralized security policy management
- Reduced infrastructure complexity
- Lower operational cost
- Improved visibility and control

STAGE – 1

Title of the project:

Replace and modernize legacy VPN architectures with a cloud-native Zscaler Zero Trust solution to reduce attack surface and lateral movement.

Overview:

Modern organizations are increasingly adopting digital transformation strategies that involve cloud computing, mobile workforces, and distributed applications. Traditional network security models were built around the concept of a fixed network perimeter, where users and devices operated inside a trusted corporate environment. However, this model has become less effective as employees, partners, and customers access resources from various locations and devices.

Legacy Virtual Private Network (VPN) architectures were originally designed to provide secure remote connectivity to internal corporate networks. While VPNs encrypt traffic and allow remote access, they often grant broad network-level permissions once a user is authenticated. This creates potential security risks because attackers who gain VPN access may move laterally across systems within the network.

With the growth of cloud-based services and Software-as-a-Service (SaaS) applications, the limitations of traditional VPNs have become more apparent. Routing traffic through centralized data centers can create network congestion, higher latency, and reduced user productivity. As organizations continue to expand their digital infrastructure, they require a more scalable and secure approach to network access.

The Zero Trust security model has emerged as a modern solution to these challenges. Zero Trust operates on the principle of “never trust, always verify,” meaning that no user or device is automatically trusted regardless of whether they are inside or outside the network. Every access request must be authenticated, authorized, and continuously validated before granting access to applications or resources.

A cloud-native security platform such as Zscaler enables organizations to implement Zero Trust architecture effectively. Instead of connecting users to the entire corporate network, the platform connects users directly to specific applications. This approach reduces the exposure of internal systems and significantly lowers the risk of unauthorized access.
By replacing legacy VPN infrastructure with a cloud-based Zero Trust solution, organizations can minimize their attack surface. Access is granted based on user identity, device health, and security policies, ensuring that only authorized users can reach sensitive resources. This also helps prevent lateral movement within the network in case of a security breach.Another key advantage of

modernizing network architecture is improved performance and scalability. Cloud-native solutions provide direct connectivity to applications without routing traffic through traditional network hubs. This reduces latency and ensures faster access to cloud applications, which is essential for maintaining productivity in remote and hybrid work environments.

Overall, adopting a Zero Trust architecture using Zscaler helps organizations strengthen security, simplify network management, and support modern digital operations. It provides a flexible and scalable framework that aligns with current technological trends while protecting organizations from evolving cyber threats.

List of Vulnerability Table:-

S.no	Category Name	Vulnerability Name	CWE/CVE - No
1	Broken Access Control	Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal')	CWE-22
2	Security Misconfiguration	J2EE Misconfiguration: Data Transmission Without Encryption	CWE-5
3	Software Supply Chain Failures	Unimplemented or Unsupported Feature in UI	CWE-447
4	Cryptographic Failures	Weak Encoding For Password	CWE-261
5	Injection	Improper Input Validation	CWE-20

6	Insecure Design	External control of file name or path	CWE-73
7	Authentication Failures	Improper Authentication	CWE-287
8	Software or Data integrity Failures	Untrusted Search Path	CWE-426
9	Security Logging and Alerting Failures	Insufficient Logging	CWE-778
10	Mishandling of Exceptional Conditions	Unchecked Return Value	CWE-252

REPORTS

1)Vulnerability Name: Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal')

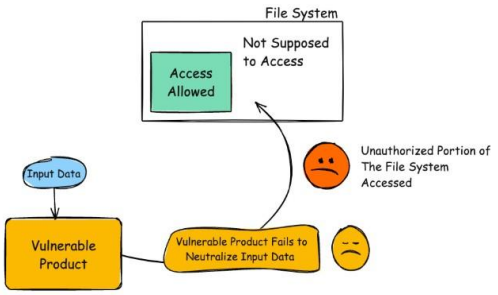
CWE/CVE: CWE-22

OWASP/SANS Category: A01:2025 Broken Access Control

Description: Path Traversal is a vulnerability that occurs when an application does not properly validate file path inputs from users. Attackers can manipulate directory paths (e.g.,.. /) to access files and directories outside the intended restricted folder.

Business Impact: Attackers may gain unauthorized access to sensitive files such as configuration files, passwords, or system data. This can lead to data breaches, exposure of confidential information, and potential system compromise. Such incidents may result in financial losses, reputational damage, and legal or regulatory consequences for the organization.

The product uses external input to construct a pathname that is intended to identify a file or directory that is located underneath a restricted parent directory, but the product does not properly neutralize special elements within the pathname that can cause the pathname to resolve to a location that is outside of the restricted directory.



Recommendations: -

1. **Input Validation and Sanitization:**
   Validate and sanitize all user inputs that are used to access files to ensure that they do not contain directory traversal characters like ../.
2. **Use Secure File Access Methods:**
   Restrict file access to predefined directories and avoid using direct user input to construct file paths.
3. **Implement Access Controls:**
   Ensure proper authentication and authorization mechanisms are in place to prevent unauthorized users from accessing sensitive resources.
4. **Use Security Libraries and Frameworks:**
   Utilize secure coding practices and built-in security features provided by programming frameworks to handle file operations safely.
5. **Regular Security Testing:**
   Conduct vulnerability scanning, penetration testing, and code reviews to detect and fix path traversal vulnerabilities early.

2)Vulnerability Name: J2EE Misconfiguration: Data Transmission Without Encryption.

CWE/CVE : CWE-5

OWASP/SANS Category: A02:2025 Security Misconfiguration

Description: Security Misconfiguration occurs when security settings in applications, servers, or databases are not properly configured or are left with default settings. This can expose systems to attackers who exploit these weaknesses to gain unauthorized access.

Business Impact: Attackers may exploit misconfigured systems to access sensitive data or system resources. It can lead to data breaches, service disruption, or unauthorized system control.

This may cause financial loss, reputational damage, and potential legal consequences for the organization.

Recommendations: -

1. **Remove Default Configurations:**
   Change default usernames, passwords, and unnecessary settings to secure configurations.
2. **Regular Security Updates:**
   Keep servers, applications, and software updated with the latest security patches.
3. **Disable Unnecessary Services:**
   Turn off unused features, services, and ports to reduce the attack surface.
4. **Implement Proper Access Control:**
   Ensure only authorized users have access to sensitive system components.
5. **Perform Regular Security Audits:**
   Conduct vulnerability scans and configuration reviews to identify and fix misconfigurations.

3)Vulnerability Name: Unimplemented or Unsupported Feature in UI

CWE/CVE: CWE-447

OWASP/SANS Category: A03:2025 Software Supply Chain Failures

Description: This vulnerability occurs when a user interface includes features or options that are not fully implemented or supported by the system. Attackers may exploit these unfinished or inactive components to bypass controls or trigger unexpected system behavior.

Business Impact: Unimplemented features may expose hidden system functions or sensitive information. Attackers could exploit these weaknesses to bypass security controls or cause system errors. This can lead to service disruption, security risks, and reduced user trust in the application.

Recommendations: -

1. Remove Incomplete Features:

All unfinished or unsupported features should be removed from the user interface until they are fully developed and tested.

2. Disable Unused UI Components:

Buttons, links, or menu options that are not functional should be disabled to prevent users or attackers from interacting with them.

3. Implement Proper Error Handling:

The system should display generic error messages and avoid revealing internal system information or code details.

4. Conduct Regular Security Testing:

Perform regular vulnerability scans, penetration testing, and code reviews to identify hidden or unsupported features.

5. Follow Secure Development Practices:

Developers should follow secure coding standards and thoroughly test new features before deploying them to production.

4)Vulnerability Name: Weak Encoding For Password

CWE/CVE: CWE-261

OWASP/SANS Category: A04:2025 Cryptographic Failures

Description: Weak encoding for passwords occurs when passwords are stored using insecure or easily reversible encoding methods instead of strong hashing algorithms. This makes it easier for attackers to decode or retrieve the original passwords if the database is compromised.

Business Impact: Attackers may be able to decode stored passwords and gain unauthorized access to user accounts. Compromised accounts can lead to data breaches, identity theft, and misuse of sensitive information. This can damage the organization's reputation and lead to financial or legal consequences.

Vulnerability Mapping Notes	
Usage	**ALLOWED** *(this CWE ID may be used to map to real-world vulnerabilities)*
Reason	Acceptable-Use
Rationale	This CWE entry is at the Base level of abstraction, which is a preferred level of abstraction for mapping to the root causes of vulnerabilities.
Comments	Carefully read both the name and description to ensure that this mapping is an appropriate fit. Do not try to 'force' a mapping to a lower-level Base/Variant simply to comply with this preferred level of abstraction.

Example 1

The following code reads a password from a properties file and uses the password to connect to a database.

Example Language: **Java** *(bad code)*

```
...
Properties prop = new Properties();
prop.load(new FileInputStream("config.properties"));
String password = Base64.decode(prop.getProperty("password"));
DriverManager.getConnection(url, usr, password);
...
```

This code will run successfully, but anyone with access to config.properties can read the value of password and easily determine that the value has been base 64 encoded. If a devious employee has access to this information, they can use it to break into the system.

Recommendations: -

1. **Use Strong Hashing Algorithms:**

   Passwords should be stored using strong hashing algorithms such as **bcrypt, Argon2, or PBKDF2** instead of simple encoding.

2. **Implement Password Salting:**

   Add a unique salt value to each password before hashing to protect against rainbow Table attacks.

3. **Enforce Strong Password Policies:**

Require users to create complex passwords with a mix of letters, numbers, and special Characters.

4. **Protect the Authentication System:**

Use secure authentication mechanisms and restrict access to password storage Databases.

5. **Perform Regular Security Audits:**

Regularly review password storage mechanisms and perform vulnerability assessments to detect weak encoding methods.

5)Vulnerability Name: Improper Input Validation.

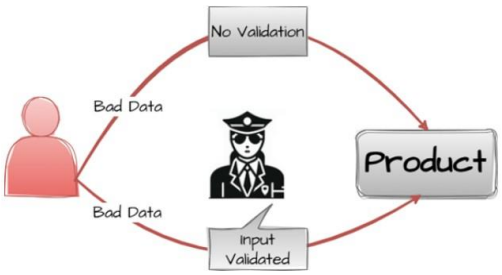
CWE/CVE: CWE-20

OWASP/SANS Category: A05:2025 Injection

Description: Injection vulnerabilities occur when untrusted user input is sent to an interpreter such as a database or command shell without proper validation. Attackers can insert malicious code (e.g., SQL, OS commands) to manipulate the system or access unauthorized data.

Business Impact: Attackers may gain unauthorized access to sensitive data stored in the database. It can lead to data modification, deletion, or complete compromise of the application. This may cause financial loss, reputational damage, and legal or regulatory issues.

The product receives input or data, but it does not validate or incorrectly validates that the input has the properties that are required to process the data safely and correctly.



Vulnerability Mapping Notes	
Usage	**DISCOURAGED** *(this CWE ID should not be used to map to real-world vulnerabilities)*
Reasons	Frequent Misuse, Frequent Misinterpretation, Abstraction
Rationale	CWE-20 is commonly misused in low-information vulnerability reports when lower-level CWEs could be used instead, or when more details about the vulnerability are available [REF-1287]. It is not useful for trend analysis. It is also a level-1 Class (i.e., a child of a Pillar). Finally, it is often used when the root cause issue is related to how input is incorrectly transformed, instead of "validated" to be correct as-is.
Comments	Within CWE, the "input validation" term focuses on the act of checking whether an input is already safe, which is different from other techniques that ensure safe processing of input. Carefully perform root-cause analysis to be sure that the issue is not due to techniques that attempt to transform potentially-dangerous input into something safe, such as filtering (CWE-790) - which attempts to remove dangerous inputs - or encoding/escaping (CWE-116), which attempts to ensure that the input is not misinterpreted when it is included in output to another component. If the issue is truly due to imroper input validation, consider using lower-level children such as Improper Use of Validation Framework (CWE-1173) or improper validation involving specific types or properties of input such as Specified Quantity (CWE-1284); Specified Index, Position, or Offset (CWE-1285); Syntactic Correctness (CWE-1286); Specified Type (CWE-1287); Consistency within Input (CWE-1288); or Unsafe Equivalence (CWE-1289).
Suggestions	

CWE-ID	Comment
CWE-1284	Specified Quantity
CWE-1285	Specified Index, Position, or Offset
CWE-1286	Syntactic Correctness
CWE-1287	Specified Type
CWE-1288	Consistency within Input
CWE-1289	Unsafe Equivalence
CWE-116	Improper Encoding or Escaping of Output
CWE-790	Improper Filtering of Special Elements

Recommendations:

1. **Input Validation:**

Validate and sanitize all user inputs to ensure they do not contain malicious code or Commands.

2. **Use Parameterized Queries:**

Use prepared statements or parameterized queries to prevent attackers from injecting SQL commands.

3. **Implement Proper Access Controls:**

Restrict database permissions so that users and applications can only access necessary Data.

4. **Use Security Frameworks:**

Use secure development frameworks and libraries that automatically protect against injection attacks.

5. **Perform Regular Security Testing:**

Conduct regular vulnerability scans, penetration testing, and code reviews to detect and fix injection vulnerabilities.

6)Vulnerability Name: External control of file name or path.

CWE/CVE: CWE-73

OWASP/SANS Category: A06:2025 Insecure Design

Description: This vulnerability occurs when an application allows users to control or modify the file name or file path used by the system without proper validation. Attackers can manipulate the file path to access, modify, or overwrite sensitive files on the server.

Business Impact: Attackers may gain unauthorized access to sensitive files stored on the system.It can lead to data leakage, file modification, or system compromise.
This may result in security breaches, financial losses, and damage to the organization's reputation.

Extended Description

This could allow an attacker to access or modify system files or other files that are critical to the application.

Path manipulation errors occur when the following two conditions are met:

1. An attacker can specify a path used in an operation on the filesystem.
2. By specifying the resource, the attacker gains a capability that would not otherwise be permitted.

For example, the program may give the attacker the ability to overwrite the specified file or run with a configuration controlled by the attacker.

Common Consequences

Impact	Details
Read Files or Directories; Modify Files or Directories	**Scope: Integrity, Confidentiality** The application can operate on unexpected files. Confidentiality is violated when the targeted filename is not directly readable by the attacker.
Modify Files or Directories; Execute Unauthorized Code or Commands	**Scope: Integrity, Confidentiality, Availability** The application can operate on unexpected files. This may violate integrity if the filename is written to, or if the filename is for a program or other form of executable code.
DoS: Crash, Exit, or Restart; DoS: Resource Consumption (Other)	**Scope: Availability** The application can operate on unexpected files. Availability can be violated if the attacker specifies an unexpected file that the application modifies. Availability can also be affected if the attacker specifies a filename for a large file, or points to a special device or a file that does not have the format that the application expects.

Recommendations: -

1. **Validate User Input:**
   Validate and sanitize all user inputs that are used to create or access file names and Paths.
2. **Restrict File Access:**
   Allow file operations only within specific authorized directories to prevent unauthorized access.
3. **Use Secure File Handling:**
   Avoid directly using user input in file system commands and use secure APIs for file operations.
4. **Implement Access Control:**
   Ensure that only authorized users have permission to access or modify important file
5. **Perform Security Testing:**
   Regularly conduct vulnerability scanning and code reviews to detect file path manipulation issues.

7)Vulnerability Name: Improper Authentication.

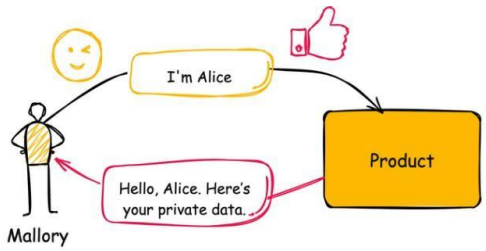
CWE/CVE CWE-287

OWASP/SANS Category: A07:2025 Authentication Failure

Description: Improper Authentication occurs when an application fails to correctly verify the identity of users before granting access to resources. Attackers can exploit weak authentication mechanisms to bypass login controls and gain unauthorized access.

Business Impact: Unauthorized users may gain access to sensitive systems or user accounts. This can lead to data theft, account takeover, or misuse of confidential information. Such incidents may cause financial loss, reputational damage, and legal consequences for the organization.

When an actor claims to have a given identity, the product does not prove or insufficiently proves that the claim is correct.



Alternate Terms	
authentification	An alternate term is "authentification", which appears to be most commonly used by people from non-English-speaking countries.
AuthN	"AuthN" is typically used as an abbreviation of "authentication" within the web application security community. It is also distinct from "AuthZ," which is an abbreviation of "authorization." The use of "Auth" as an abbreviation is discouraged, since it could be used for either authentication or authorization.
AuthC	"AuthC" is used as an abbreviation of "authentication," but it appears to used less frequently than "AuthN."

Recommendations: -

1. **Implement Strong Authentication:**
   Use secure authentication methods such as multi-factor authentication (MFA) to verify user identity.
2. **Enforce Strong Password Policies:**
   Require complex passwords and regular password updates to reduce the risk of unauthorized access.
3. **Secure Session Management:**
   Use secure session tokens and ensure sessions expire after a certain period of Inactivity.

4.**Limit Login Attempts:**

Implement account lockout mechanisms after multiple failed login attempts to prevent brute-force attacks.

5.**Regular Security Monitoring:**

Monitor authentication activities and perform regular security testing to detect and prevent authentication vulnerabilities.

8)Vulnerability Name: Untrusted Search Path

CWE/CVE: CWE-426

OWASP/SANS Category: A08:2025 Software or Data Integrity Failures

Description: Untrusted Search Path vulnerability occurs when an application searches for executable files or libraries in directories that may be controlled by attackers. This allows attackers to place malicious files in those locations so the system executes them instead of the legitimate ones.

Business Impact: Attackers may execute malicious programs with the same privileges as the application. This can lead to system compromise, unauthorized access, or malware installation. It may result in data loss, operational disruption, and damage to the organization's reputation.

Extended Description

This might allow attackers to execute their own programs, access unauthorized data files, or modify configuration in unexpected ways. If the product uses a search path to locate critical resources such as programs, then an attacker could modify that search path to point to a malicious program, which the targeted product would then execute. The problem extends to any type of critical resource that the product trusts.

Some of the most common variants of untrusted search path are:

- In various UNIX and Linux-based systems, the PATH environment variable may be consulted to locate executable programs, and LD_PRELOAD may be used to locate a separate library.
- In various Microsoft-based systems, the PATH environment variable is consulted to locate a DLL, if the DLL is not found in other paths that appear earlier in the search order.

Recommendations: -

1. **Use Absolute File Paths:**
   Always specify full and trusted paths for executables and system files instead of relying on search paths.
2. **Restrict Directory Permissions:**
   Limit write permissions to system directories to prevent attackers from placing malicious files.
3. **Validate Executable Sources:**
   Ensure that applications only load executables or libraries from trusted and verified locations.
4. **Implement Secure Configuration:**
   Configure the system environment variables and search paths securely to avoid untrusted directories.
5. **Perform Security Audits:**
   Regularly review application configurations and conduct vulnerability scans to detect untrusted search path issues.

9)Vulnerability Name: Insufficient Logging

CWE/CVE: CWE-778

OWASP/SANS Category: A09:2025 Security logging And Alerting Failures.

Description: Insufficient Logging occurs when an application or system does not properly record security-related events or user activities. Without proper logs and monitoring, suspicious or malicious activities may go undetected.

Business Impact: Security incidents may not be detected quickly, allowing attackers to continue their activities unnoticed. It becomes difficult to investigate attacks or identify the root cause of security breaches. This can lead to data loss, financial damage, and serious harm to the organization's reputation.

Extended Description

When security-critical events are not logged properly, such as a failed login attempt, this can make malicious behavior more difficult to detect and may hinder forensic analysis after an attack succeeds.

As organizations adopt cloud storage resources, these technologies often require configuration changes to enable detailed logging information, since detailed logging can incur additional costs. This could lead to telemetry gaps in critical audit logs. For example, in Azure, the default value for logging is disabled.

Vulnerability Mapping Notes	
Usage	ALLOWED *(this CWE ID may be used to map to real-world vulnerabilities)*
Reason	Acceptable-Use
Rationale	This CWE entry is at the Base level of abstraction, which is a preferred level of abstraction for mapping to the root causes of vulnerabilities.
Comments	Carefully read both the name and description to ensure that this mapping is an appropriate fit. Do not try to 'force' a mapping to a lower-level Base/Variant simply to comply with this preferred level of abstraction.

Recommendations: -

1. **Implement Comprehensive Logging:**
   Record important events such as login attempts, access to sensitive data, and system changes.
2. **Enable Real-Time Monitoring:**
   Use monitoring tools to detect unusual activities and potential security threats in real time.
3. **Protect Log Integrity**:
   Store logs securely and prevent unauthorized modification or deletion.
4. **Regular Log Review:**
   Periodically review and analyze logs to identify suspicious behavior.
5. **Use Security Information and Event Management (SIEM):**
   Implement SIEM tools to collect, analyze, and respond to security events efficiently.

10)Vulnerability Name: Unchecked Return Value

CWE/CVE: CWE-252

OWASP/SANS Category: A09:2025 Security logging And Alerting Failures.

Description: Unchecked Return Value occurs when a program fails to verify the return value of a function or system call. This may cause the application to continue execution even when an error or failure has occurred.

Business Impact: Ignoring return values can lead to unexpected system behavior or application crashes. Attackers may exploit these weaknesses to bypass security checks or trigger system failures. This can result in service disruption, data corruption, or reduced reliability of the application.

Description

The product does not check the return value from a method or function, which can prevent it from detecting unexpected states and conditions.

Extended Description

Two common programmer assumptions are "this function call can never fail" and "it doesn't matter if this function call fails". If an attacker can force the function to fail or otherwise return a value that is not expected, then the subsequent program logic could lead to a vulnerability, because the product is not in a state that the programmer assumes. For example, if the program calls a function to drop privileges but does not check the return code to ensure that privileges were successfully dropped, then the program will continue to operate with the higher privileges.

In the following example, it is possible to request that memcpy move a much larger segment of memory than assumed:

Example Language: **C** (bad code)

```
int returnChunkSize(void *) {

  /* if chunk info is valid, return the size of usable memory,

  * else, return -1 to indicate an error

  */
  ...
}
int main() {
  ...
  memcpy(destBuf, srcBuf, (returnChunkSize(destBuf)-1));
  ...
}
```

If returnChunkSize() happens to encounter an error it will return -1. Notice that the return value is not checked before the memcpy operation (CWE-252), so -1 can be passed as the size argument to memcpy() (CWE-805). Because memcpy() assumes that the value is unsigned, it will be interpreted as MAXINT-1 (CWE-195), and therefore will copy far more memory than is likely available to the destination buffer (CWE-787, CWE-788).

Recommendations:-

1. **Validate Return Values:**

Always check the return value of functions and system calls to ensure operations are completed successfully.

2. **Implement Proper Error Handling:**

Handle errors appropriately by logging them and taking corrective actions when failures Occurs.

3. **Use Secure Coding Practices:**

Follow secure coding standards that require validation of function outputs.

4. **Conduct Code Reviews:**

Perform regular code reviews to ensure developers are properly checking return values.

5. **Perform Testing and Debugging:**

Use static analysis tools and thorough testing to detect unchecked return value issues Early.

STAGE – 2

Overview :-

Nessus is a vulnerability scanner developed by Tenable, Inc. It is a remote scanner, meaning that it does not need to be installed on the target host to scan it. Nessus works by sending a variety of probes to the target host in order to identify vulnerabilities. These probes can include network traffic, operating system commands, and application requests. Nessus uses a plugin-based architecture. Plugins are small pieces of code that are designed to identify specific vulnerabilities. There are over 1200 plugins available for Nessus, covering a wide range of vulnerabilities in operating systems, applications, and network devices. When Nessus scans a host, it first uses a discovery plugin to identify the operating system and services running on the host. Once the host has been discovered, Nessus runs a series of plugins to test for vulnerabilities. For each vulnerability that Nessus finds, it provides a detailed report that includes the severity of the vulnerability, the steps to reproduce the vulnerability, and the steps to remediate the vulnerability.

Nessus can be used to scan a variety of targets, including single hosts, networks, and web applications. It can also be used to scan specific ports and services. Nessus can be configured to run scans on a schedule or manually.

Here is a step-by-step explanation of how Nessus works:

1. Nessus connects to the target host using a variety of protocols, including TCP, UDP, and ICMP.
2. Nessus sends a series of probes to the target host in order to identify its operating system and services.
3. Nessus runs a series of plugins to test for vulnerabilities.
4. Nessus generates a report that includes the severity of each vulnerability, the steps to reproduce the vulnerability, and the steps to remediate the vulnerability.

Nessus is a valuable tool for security professionals who need to identify and remediate vulnerabilities in their networks. It is easy to use and provides comprehensive reports that can be used to priorities remediation efforts.

Here are some of the benefits of using Nessus:

- **Comprehensive vulnerability coverage:**
  Nessus has over 1200 plugins available, covering a wide range of vulnerabilities in operating systems, applications, and network devices.
- **Easy to use:**
  Nessus has a user-friendly interface that makes it easy to configure and run scans
- **Comprehensive reporting:**

Nessus provides detailed reports that include the severity of each vulnerability, the steps to reproduce the vulnerability, and the steps to remediate the vulnerability.

- **Scalability:**

  Nessus can be used to scan a variety of targets, including single hosts, networks, and web applications.

- **Flexibility:**

  Nessus can be configured to run scans on a schedule or manually.

Nessus is a powerful tool that can be used to improve the security of any network. It is a valuable asset for any security professional.

- **Target website: https://demo.testfire.net/**
- **Target ip address:** 65.61.137.117

List of Vulnerabilities: -

S.no	Vulnerability Name	Severity	Plugins
1	Nessus SYN scanner	INFO	11219
2	Service Detection	INFO	22964
3	Apache Tomcat Detection	INFO	39446
4	SSL / TLS Versions Supported	INFO	56984
5	Device Type	INFO	54615

6	ICMP Timestamp Request Remote Date Disclosure	LOW	10114
7	OS Identification	INFO	11936
8	Additional DNS Hostnames	INFO	46180

REPORTS

1)Vulnerability Name: Nessus SYN scanner

Severity: INFO

Plugin: 11219

Port: 443

Description: This plugin is a SYN 'half-open' port scanner. It shall be reasonably quick even against a firewalled target. Note that SYN scans are less intrusive than TCP (full connect) scans against broken services, but they might cause problems for less robust firewalls and also leave unclosed connections on the remote target, if the network is loaded.

Solution: Protect your target with an IP filter.

Business Impact: The **SYN Scanner** used in Nessus helps identify open ports and services on network systems by sending SYN packets to target hosts. If a vulnerability is detected through this scanning method, it can expose critical services that may be exploited by attackers. The business impact of such vulnerabilities includes unauthorized access to internal systems, potential data breaches, and disruption of business operations. Attackers may use the information gathered from open ports to launch further attacks such as malware injection or denial-of-service attacks.

2)Vulnerability Name: Service Detection

Severity: INFO

Plugin: 22964

Port: 443

Description: This plugin attempts to determine the type and the version of the remote web server.

Solution:

The remote web server type is : Apache-Coyote/1.1

Business Impact: Service detection in vulnerability scanning tools like Nessus identifies the services and applications running on open ports of a system. If vulnerabilities are found in these detected services, attackers may exploit them to gain unauthorized access to the network. This can lead to serious business impacts such as data breaches, system compromise, and disruption of critical services. Insecure or outdated services may also allow attackers to execute malicious code or steal sensitive business information. As a result, organizations may face financial losses, operational downtime, and damage to their reputation.

3)Vulnerability Name: Apache Tomcat Detection

Severity: INFO

Plugin: 39446

Port: 443

Description: Nessus was able to detect a remote Apache Tomcat web server.

Solution: When **Apache Tomcat** is detected during vulnerability scanning (using tools like Nessus), it is important to verify the installed version and check for known vulnerabilities.

Business Impact: If vulnerable Apache Tomcat servers are exposed, attackers may exploit known weaknesses to gain unauthorized access or execute malicious code. This can result in data breaches, website defacement, or service downtime. Compromised servers may also be used to

launch further attacks within the organization's network. Such incidents can lead to financial losses, legal consequences, and reputational damage. Therefore, securing Apache Tomcat is critical to maintaining business continuity and protecting sensitive information.

4)Vulnerability Name: SSL / TLS Versions Supported

Severity: INFO

Plugin: 56984

Port: 443

Description: This plugin detects which SSL and TLS versions are supported by the remote service for encrypting communications.

Solution: Organizations should ensure that only secure and modern encryption protocols are enabled on their servers. Outdated protocols such as **SSL 2.0**, **SSL 3.0**, and older versions like **TLS 1.0** and **TLS 1.1** should be disabled because they contain known security vulnerabilities. Instead, servers should support secure versions such as **TLS 1.2** and **TLS 1.3**.

Business Impact: If a system supports weak SSL/TLS versions, attackers may exploit these vulnerabilities to intercept or decrypt sensitive information transmitted over the network. This could expose confidential business data, user credentials, or financial transactions. Such security breaches may result in data theft, compliance violations, and damage to the organization's reputation. Ensuring the use of secure TLS versions helps protect data integrity, maintain customer trust, and support safe online communications.

5)Vulnerability Name: Device Type

Severity: INFO

Plugin: 54615

Port: 0

Description: Based on the remote operating system, it is possible to determine what the remote system type is (eg: a printer, router, general-purpose computer, etc).

Solution: Device type detection identifies the category of device connected to the network, such as servers, routers, firewalls, workstations, or IoT devices. Tools like Nessus help administrators determine what type of device is running on a particular IP address.

Business Impact: If unauthorized or vulnerable device types are present on the network, attackers may exploit them as entry points to gain access to sensitive systems. Compromised devices can lead to data breaches, malware spread, or network downtime. Insecure IoT or outdated networking devices may also weaken overall security posture.

6)Vulnerability Name: ICMP Timestamp Request Remote Date Disclosure

Severity: LOW

Plugin: 10114

Port: 0

Description: The remote host answers to an ICMP timestamp request. This allows an attacker to know the date that is set on the targeted machine, which may assist an unauthenticated, remote attacker in defeating time-based authentication protocols.

Solution: Filter out the ICMP timestamp requests (13), and the outgoing ICMP timestamp replies (14).

Business Impact: If this vulnerability is present, attackers may obtain the system's date and time remotely. Although it may seem minor, this information can help attackers plan and coordinate further attacks on the system. It may also assist in identifying system uptime and configuration details.

7)Vulnerability Name: OS Identification

Severity: INFO

Plugin: 11936

Port: 0

Description: This plugin is a SYN 'half-open' port scanner. It shall be reasonably quick even against a firewalled target.

Solution: Protect your target with an IP filter.

Business Impact: This is an informational finding indicating that the port is reachable and responds to SYN scan requests. If attackers can identify open ports through such scans, they may use this information to discover running services and attempt **further reconnaissance or targeted attacks** against exposed services on the system.

8)Vulnerability Name: Additional DNS Hostnames

Severity: INFO

Plugin: 46180

Port: N/A

Description: Hostnames different from the current hostname have been collected by miscellaneous plugins. Nessus has generated a list of hostnames that point to the remote host. Note that these are only the alternate hostnames for hosts discovered on a web server. **Solution:** If you want to test them, re-scan using the special vhost syntax, such as : www.example.com[192.0.32.10]

Business Impact: The presence of additional DNS hostnames may expose **extra domains or subdomains associated with the server**, which attackers can use for reconnaissance to discover hidden services, misconfigured systems, or potential entry points for further attacks.

STAGE – 3

REPORTS:

Title: Replace and modernize legacy VPN architectures with a cloud-native Zscaler Zero Trust solution to reduce attack surface and lateral movement.

1. Legacy VPN Architecture

Legacy VPN architecture was designed when most users worked inside office networks and applications were hosted in on-premises data centers. VPN creates an encrypted tunnel between the user and corporate network. Once authenticated, users are connected directly to the internal network. However, this model assumes that users inside the network are trusted. It provides network-level access instead of application-level access.

- VPN provides secure communication through encrypted tunnels.
- Users connect to the internal network using VPN clients.
- Once authenticated, users gain access to internal resources.
- VPN was mainly designed for on-premises environments.
- Network access is provided at the infrastructure level.
- VPN servers or concentrators are required to manage connections.

2. Limitations of Traditional VPN

Traditional VPN solutions expose internal IP addresses and network resources to connected users. If login credentials are stolen, attackers can access multiple systems within the network. This increases the attack surface and risk of internal compromise.VPN also routes traffic through centralized data centers, causing latency and slower application performance. Scaling VPN requires additional hardware and configuration. Managing multiple VPN gateways across branches increases operational complexity. These limitations make VPN inefficient for today's distributed workforce.

- VPN exposes the internal network to connected users.
- If credentials are stolen, attackers may gain network access.
- Allows lateral movement within the network.
- VPN traffic is routed through centralized data centers.
- This routing causes latency and slower application performance.
- VPN infrastructure is expensive to scale.

3. Zero Trust Security Model

Zero Trust is a security framework based on the principle "Never Trust, Always Verify." It does not automatically trust users or devices, even if they are inside the network. Every access request must be authenticated, authorized, and continuously validated.Access is granted based on identity, device health, location, and security policies. Zero Trust provides least-privilege access, meaning users can only access what they need. It reduces insider threats and credential-based attacks. Continuous monitoring ensures suspicious activities are detected quickly. This model is more suitable for cloud-based and remote environments.

- Follows the principle **"Never Trust, Always Verify."**
- Every user and device must be authenticated.
- Access is granted based on identity verification.
- Device health and security posture are checked.
- Access is limited to only required resources.
- Continuous monitoring of user activity is performed.
- Reduces insider threats and credential misuse.

4. Cloud-Native Security Architecture

Cloud-native architecture delivers security services from the cloud instead of physical hardware appliances. Security controls such as firewall, web filtering, and access management are hosted in the cloud.This approach allows scalability without purchasing additional hardware. Users can securely access applications directly through the cloud. Policies are centrally managed

and applied globally. It reduces dependency on traditional data centers. Cloud-native architecture supports hybrid work models and improves overall network performance.

- Security services are hosted in the cloud.
- Reduces dependency on physical network appliances.
- Provides scalability and flexibility.
- Policies can be managed from a central platform.
- Users can securely access applications from any location.
- Supports remote and hybrid work environments.
- Reduces hardware and maintenance costs.

5. Zscaler Zero Trust Platform

The Zscaler Zero Trust platform connects users directly to applications without exposing the internal network. Instead of placing users on the corporate network, it creates a secure, application-specific connection.It verifies identity through authentication mechanisms such as multi-factor authentication (MFA). Device posture checks ensure that only secure devices can access applications. Applications remain hidden from the internet, reducing exposure. The platform also provides centralized monitoring and logging for better visibility. This ensures secure and controlled access for users worldwide.

- Connects users directly to applications instead of networks.
- Verifies identity through authentication methods.
- Supports multi-factor authentication (MFA).
- Performs device security checks before access.
- Provides centralized policy management.
- Monitors user activity and network traffic.
- Protects sensitive applications from internet exposure.

Benefits of Replacing Legacy VPN with Cloud-Native Zero Trust

Modernizing legacy VPN architectures with a cloud-native Zero Trust solution such as Zscaler provides significant security and operational benefits for organizations. Instead of granting users full network access, Zero Trust allows secure, identity-based access only to authorized applications. This approach reduces security risks, protects sensitive data, and prevents attackers from moving within the network if a breach occurs. In addition, cloud-based connectivity improves performance, simplifies network management, and supports remote and hybrid work environments. As a result, organizations can achieve stronger cybersecurity while maintaining flexibility and scalability in their IT infrastructure.

- Reduces the attack surface by hiding internal applications from the public internet.
- Prevents lateral movement by giving users access only to specific applications.
- Improves network performance with direct and secure cloud connectivity.

Conclusion:

In conclusion, exploring the Replace and modernize legacy VPN architectures with a cloud-native Zero Trust solution using Zscaler has been an insightful journey through various stages.

Stage 1: The first stage of the project focused on analyzing the traditional VPN infrastructure used for providing remote access to organizational networks. During this stage, the limitations and security risks associated with legacy VPN systems were studied in detail. Traditional VPN architectures allow users to connect directly to the internal network once they are authenticated, which increases the exposure of internal resources. This approach creates a larger attack surface and allows attackers to move laterally across the network if credentials are compromised. The analysis also highlighted issues such as network congestion, complex management, and limited scalability in modern cloud environments. From this stage, it became clear that traditional VPN solutions are not sufficient to meet the security requirements of modern organizations. Therefore, organizations need a more advanced and secure model to protect their networks and sensitive data.

Stage 2: The second stage of the project focused on the implementation of the Zero Trust security model to overcome the limitations of legacy VPN systems. The Zero Trust approach follows the principle of "never trust, always verify," which ensures that every user and device must be authenticated before gaining access to applications or services. In this stage, a cloud-native security solution such as Zscaler was considered to provide secure and controlled access to organizational resources. Instead of granting full network access, users are connected directly to specific applications based on identity and security policies. This approach reduces the risk of unauthorized access and protects critical resources from potential cyber threats. The implementation of Zero Trust also improves visibility, monitoring, and access control, which helps organizations maintain a stronger security posture.

Stage 3: The third stage of the project focused on the deployment and optimization of the cloud-native Zero Trust architecture. In this stage, the system was evaluated to ensure that it provides secure and efficient access to applications without exposing the internal network. The use of a cloud-based security platform such as Zscaler helps organizations reduce their attack surface and prevent lateral movement within the network. Continuous monitoring, policy enforcement, and centralized management allow administrators to maintain strong security controls while supporting remote and hybrid work environments. This stage demonstrates how modern network security solutions can replace outdated VPN infrastructure and provide scalable, reliable, and secure connectivity. Overall, the successful deployment of Zero Trust architecture enhances organizational security, improves network performance, and supports future technological advancements.

Future Scope:

1) Future of Legacy VPN Replacement

The future of network security is moving away from traditional VPN-based architectures toward more secure and scalable solutions. As organizations continue adopting cloud computing, remote work, and mobile access, legacy VPN systems will become less effective. Businesses will increasingly look for advanced security models that provide stronger protection against cyber threats.

Replacing traditional VPN infrastructure with modern security frameworks will help organizations reduce network vulnerabilities and improve overall system performance.

Here are some key trends expected in the future of VPN modernization:

• Increased adoption of Zero Trust security models: Organizations will gradually move away from network-based trust models and adopt Zero Trust frameworks to improve access control and data protection.

• Growth of cloud-native security platforms: Companies will increasingly rely on cloud-based solutions such as Zscaler to provide secure application access without exposing internal networks.

• Enhanced remote workforce security: As remote and hybrid work environments continue to grow, modern security solutions will provide safer access to business applications from any location.

2) Future of Zero Trust Implementation

The Zero Trust security model will play a critical role in the future of cybersecurity. Organizations will continue integrating identity-based access control and continuous verification mechanisms into their network infrastructure. Instead of trusting users based on network location, future systems will verify user identity, device health, and access policies before granting access to resources.

Key developments expected in Zero Trust implementation include:

• Integration with advanced authentication technologies: Multi-factor authentication (MFA), biometric verification, and identity management systems will enhance security.

• Use of artificial intelligence in threat detection: AI-based systems will help identify suspicious activities and automatically respond to potential cyber threats.

• Expansion across enterprise environments: Zero Trust architecture will be implemented across all organizational systems, including cloud platforms, data centers, and remote devices.

3) Future of Cloud-Based Network Security

Cloud-based security solutions will continue to evolve to support the growing demand for secure digital environments. As businesses adopt more cloud services and distributed networks, traditional security models will be replaced with scalable cloud-native architectures.

Important future trends include:

• Automated security policy management: Advanced systems will automatically update and enforce security policies across the network.

• Improved security analytics and monitoring: Organizations will use real-time monitoring tools to detect and respond to threats quickly.

• Global secure access for applications: Cloud-native platforms will provide secure and efficient access to applications from anywhere in the world.

Topics explored:

Legacy VPN Architecture and Remote Access Mechanisms, Limitations of Traditional VPN Security Models, Zero Trust Architecture Principles, Identity and Access Management (IAM), Multi-Factor Authentication (MFA), Cloud-Native Security Architecture, Secure Access Service Edge (SASE) Concepts, Attack Surface Reduction Techniques, Prevention of Lateral Movement, Network Segmentation and Micro-Segmentation, Application-Level Access Control, Security Policy Enforcement and Monitoring, Threat Detection and Response, Secure Remote Workforce Enablement, Risk Assessment and Vulnerability Analysis.

Tools explored:

- Nmap,
- Nessus,
- Metasploit,
- Kali Linux,
- OWASP ZAP,
- Burp Suite,
- Zscaler Platform.

THE END